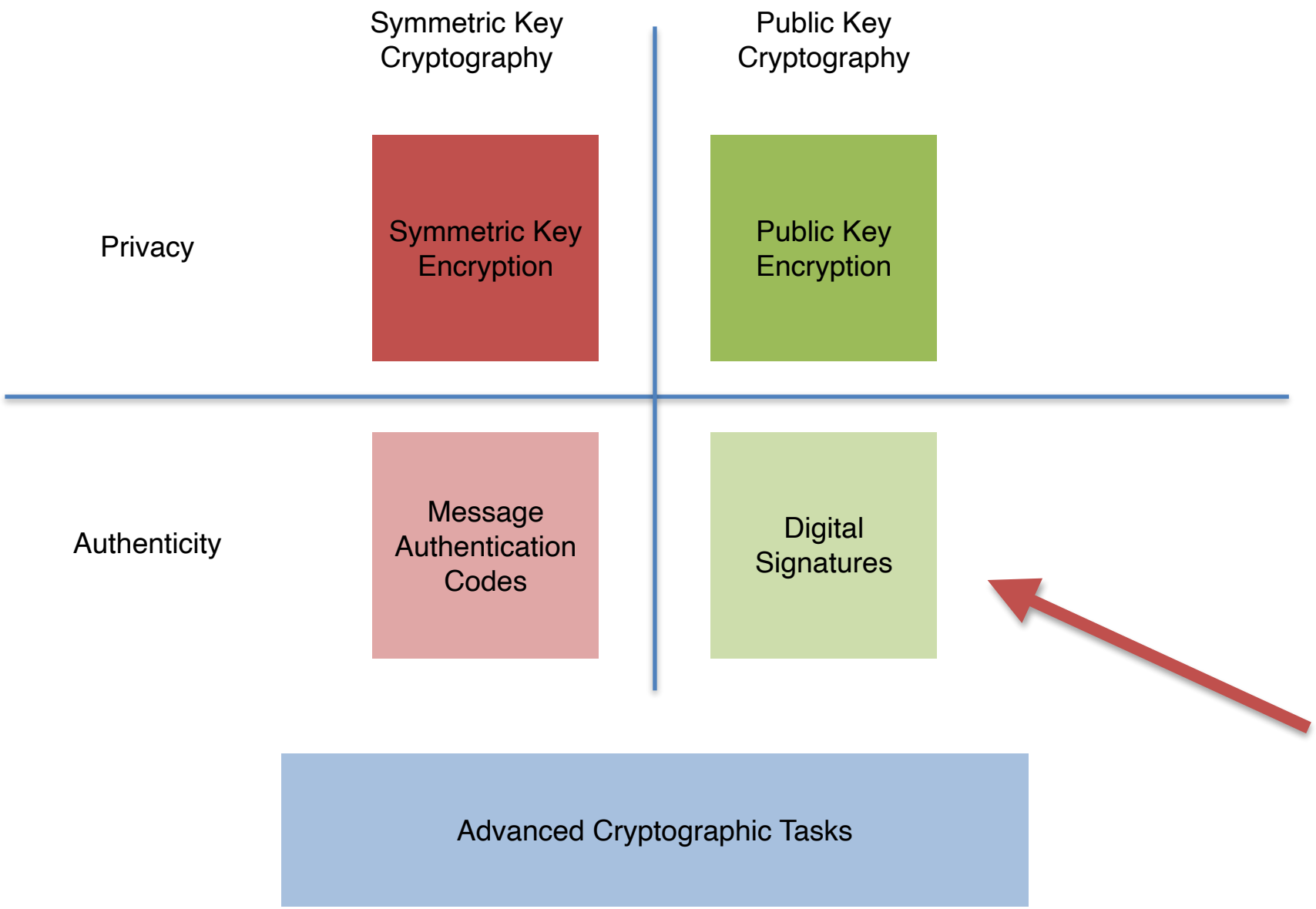
CISPA
HELMHOLTZ CENTER FOR INFORMATION SECURITY

Cryptography

Chapter 9.1: Digital Signatures Definitions

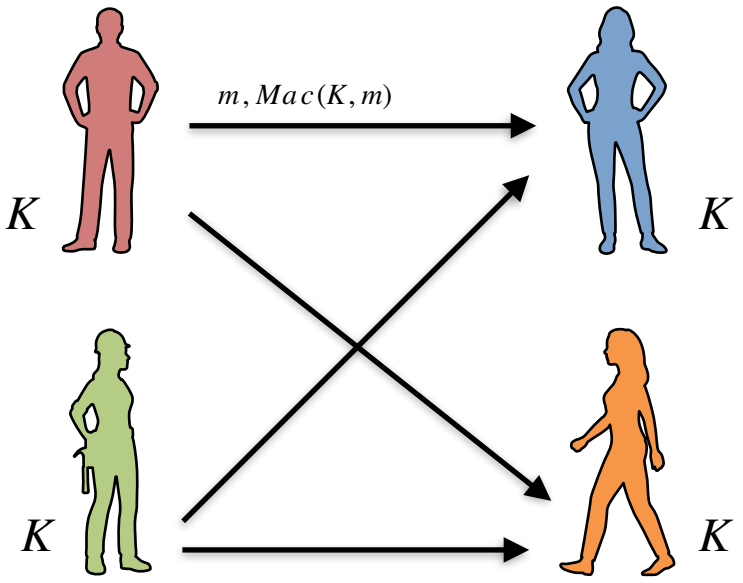
Julian Loss

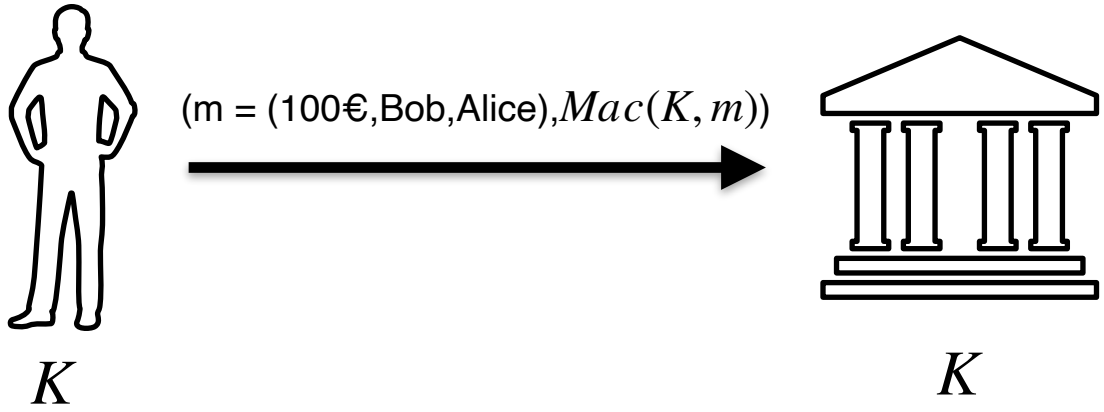
Course Topics



Recap Authentication

- Integrity of messages within a closed group
- Authentication is symmetric: Anyone who can verify authenticated messages in the group can also authenticate
- Should your bank be able to authenticate transaction on behalf of you?
- Can we separated Authentication and Verification?

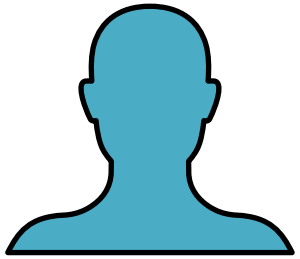




RSA Signatures

- The notion of digital signatures was introduced by Rivest, Shamir and Adleman ’78
- Authentication/Signing uses a secret signing key, verification a public verification key
- This was the first non-encryption use of cryptography
- Idea: Run the textbook RSA encryption scheme *in reverse*
- Idea for Security: RSA function $m^e \mod N$ hard to invert, so it shouldn’t be possibly to sign without knowledge of sk

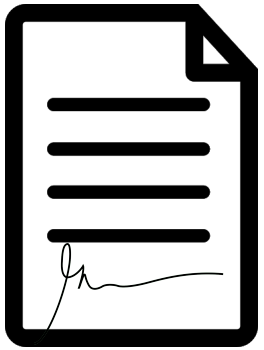
$sk = (N, d)$

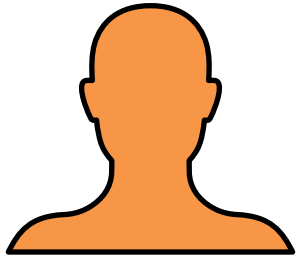


$\sigma \leftarrow m^d \mod N$

$pk = (N, e)$

$m \quad \sigma$





$\sigma^e \mod N \stackrel{?}{=} m$

Issues

- Problem: Textbook RSA is *malleable*
- Given signatures on m_1 and m_2, you can create a signature on $m_1 \cdot m_2$
- You can also create signatures of random messages
- How should we define security for signatures?
- Similar to Message Authentication Codes!
- Also note: Signatures are not the reverse of public key encryption

Digital Signature Schemes

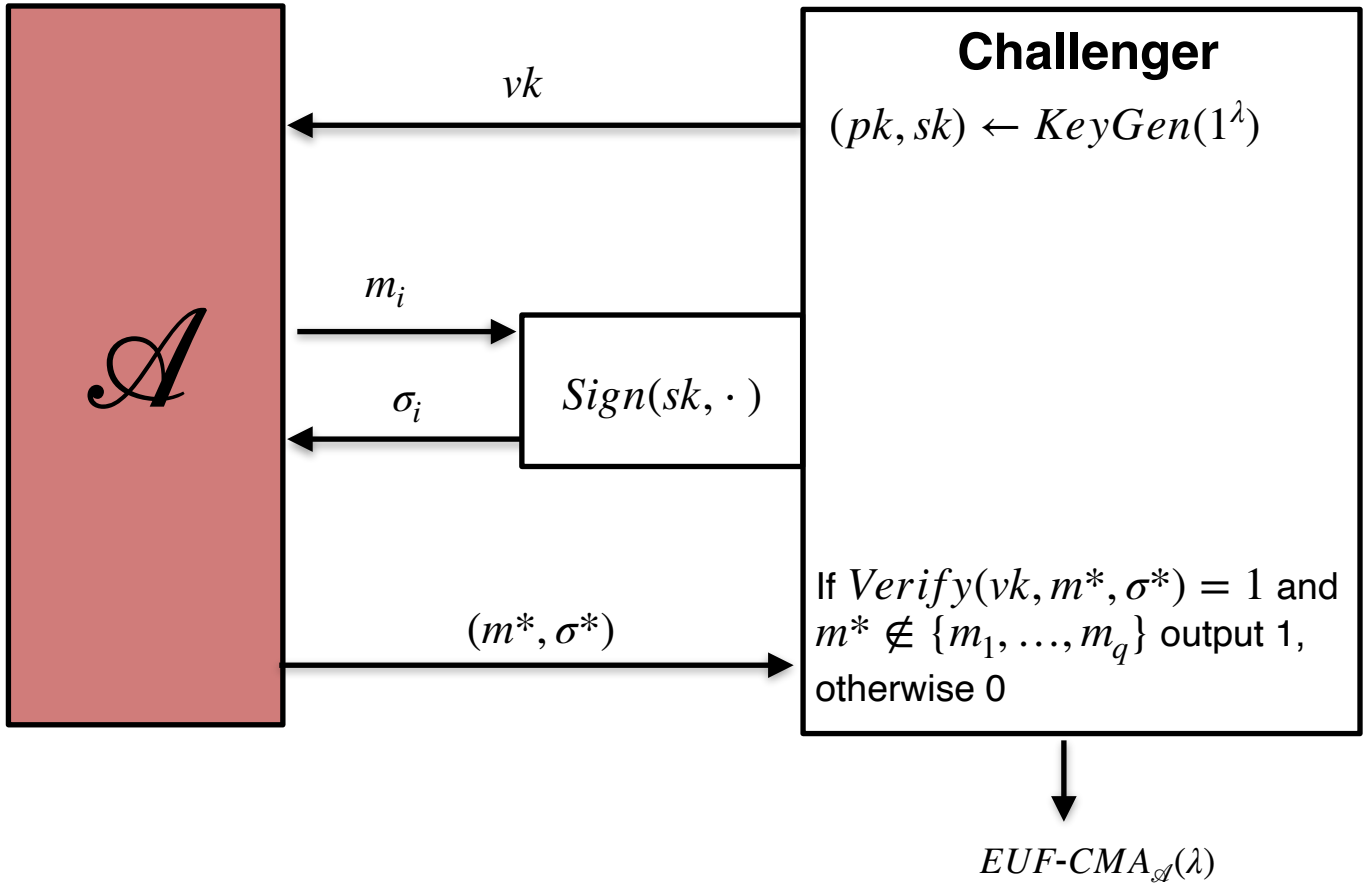
Syntax: A digital signature scheme consists of three PPT algorithms: $(Gen, Sign, Verify)$

- $Gen(1^\lambda)$: A randomized algorithm which takes as input the security parameter 1^λ (encoded in unary) and outputs a pair of **verification** and **signing** keys (vk, sk)
- $Sign(sk, m)$: A randomized algorithm which takes a signing key sk and message m as input and outputs a signature σ
- $Verifiy(vk, m, \sigma)$: A deterministic algorithm which takes as a verification key vk, a message m and a signature σ as input and outputs a bit $b \in \{0,1\}$

Correctness: It holds for all $\lambda \in \mathbb{N}$ and all messages m that $\Pr[Verify(vk, m, Sign(sk, m)) = 1] = 1$, where $(vk, sk) \leftarrow Gen(1^\lambda)$

Existential Unforgeability under Chosen Message Attacks

$EUF\text{-}CMA_{\mathscr{A}}(\lambda)$ Experiment:



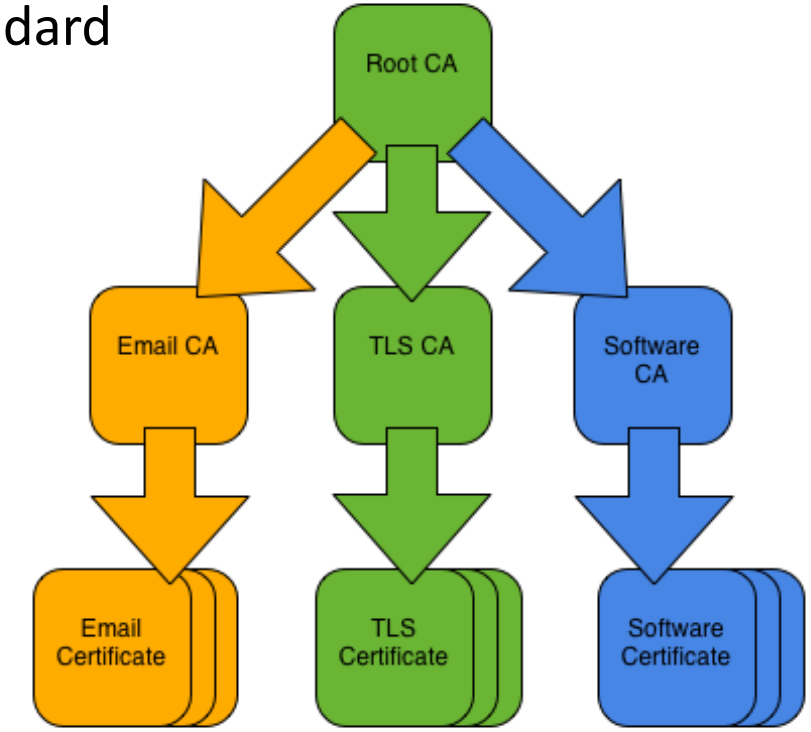
Definition

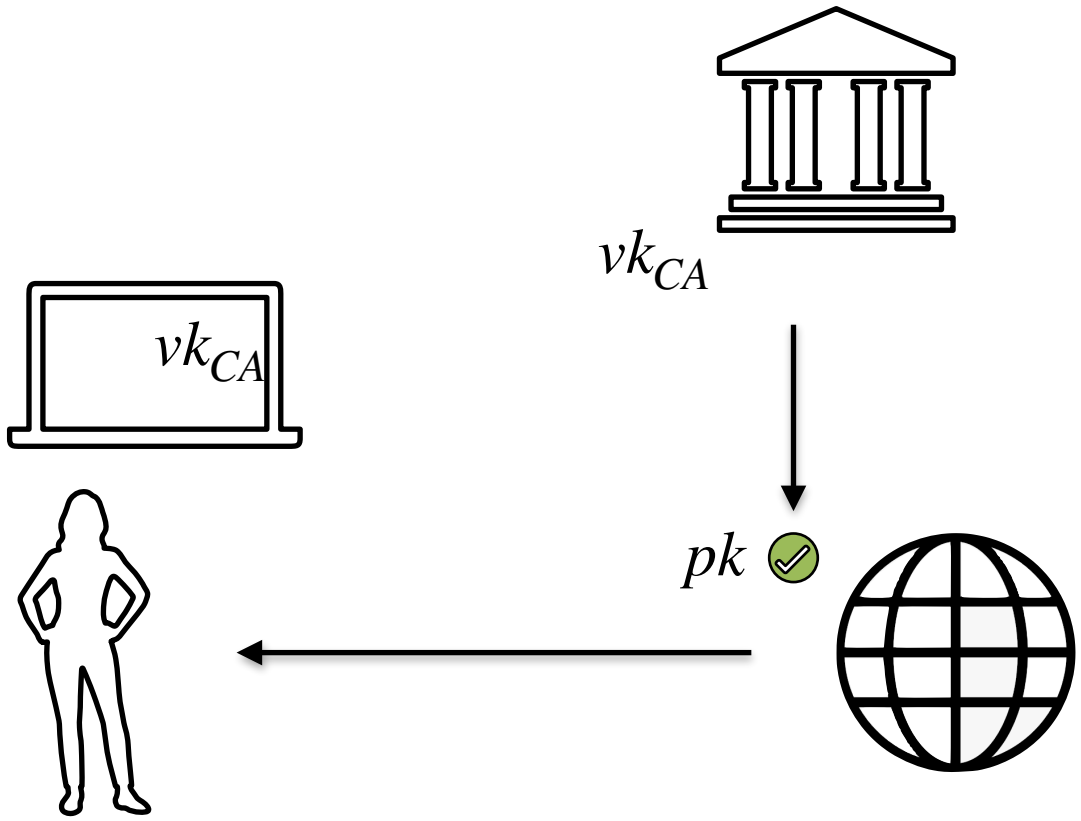
An signature scheme $(Gen, Sign, Verify)$ is $EUF\text{-}CMA$-**secure**, if it holds for **every PPT-adversary** $\mathscr{A}$ there exists a negligible function ν s.t. for all $\lambda \in \mathbb{N}$

$$\Pr[EUF\text{-}CMA_{\mathscr{A}}(\lambda) = 1] < \nu(\lambda)$$

Applications: Certificates

- How do you know you can trust a web-service?
- Certification Authority (CA) which certifies that someone can be trusted
- Trust in CA needs to be *bootstrapped*
- X.509 Standard





RSA Hash-and-Sign

- We will now construct an EUF-CMA secure variant of the RSA signatures
- Idea: Hash message first, then sign
- Let $RSAGen$ be an RSA instance generation algorithm and $H : \{0,1\}^* \to \mathbb{Z}_N$ be a hash function
- The RSA Hash-and-Sign scheme $(Gen, Sign, Verify)$ is given as follows
  - $Gen(1^\lambda)$: Compute $(N, e, d) \leftarrow RSAGen(1^\lambda)$. Output $vk \leftarrow (N, e)$ and $sk \leftarrow (N, d)$
  - $Sign(sk = (N, d), m)$: Compute and outputs $\sigma \leftarrow H(m)^d \mod N$
  - $Verify(vk = (N, e), m, \sigma)$: If $\sigma^e = H(m)$ output 1, otherwise 0

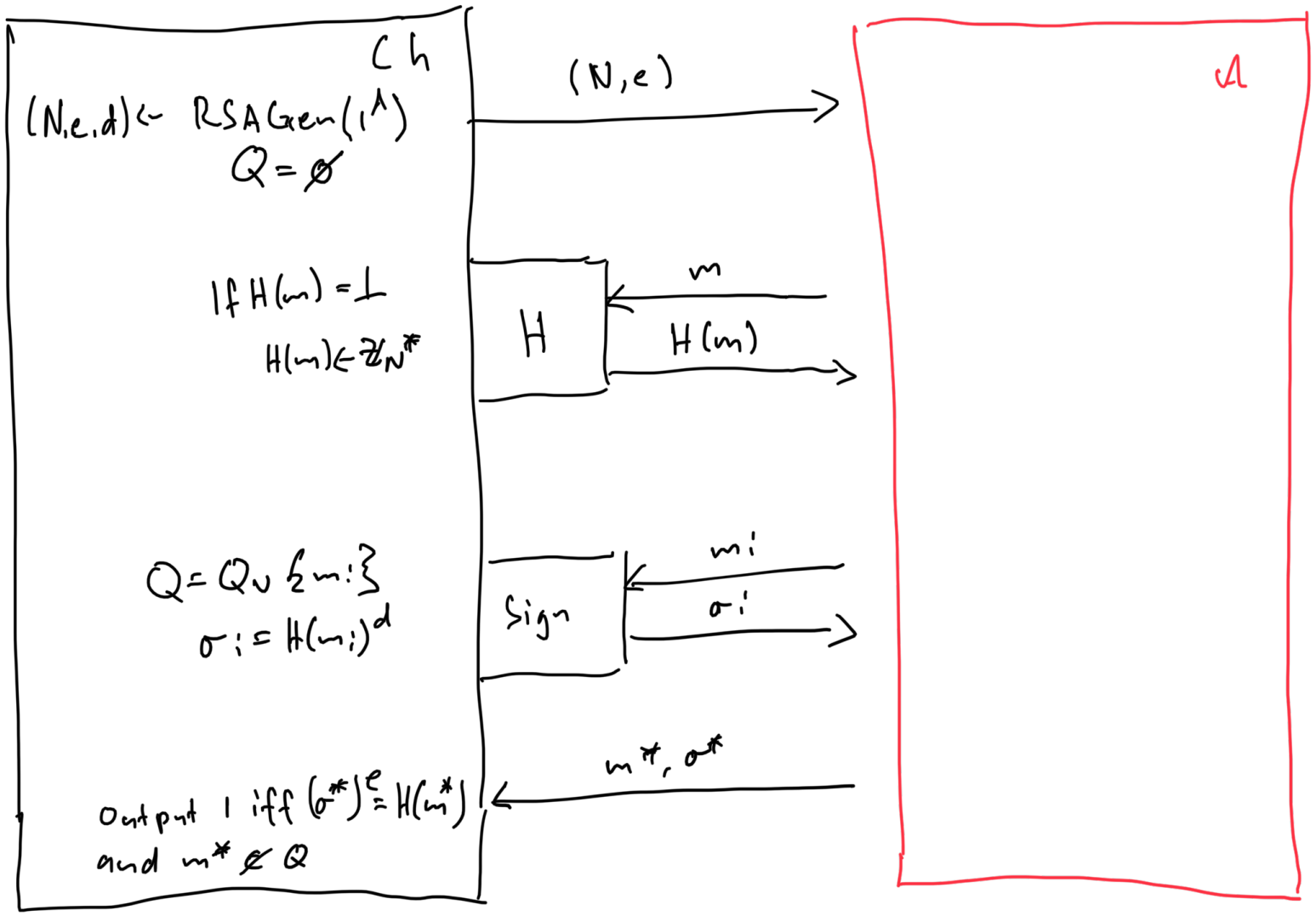
$$m \xrightarrow{H} H(m) \longrightarrow \sigma_m$$

EUF-CMA Security

Theorem 8.2

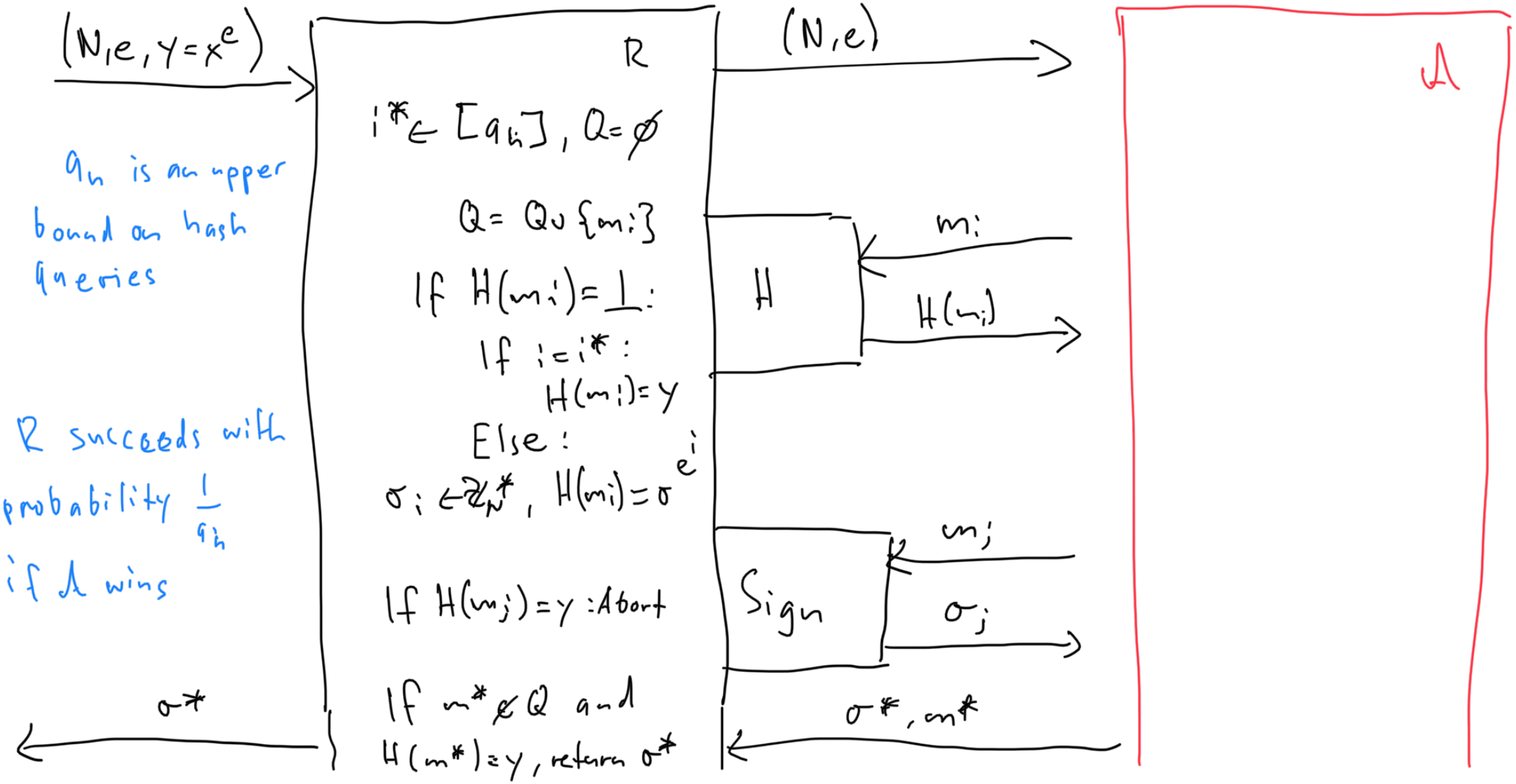
- Assume that the RSA assumption holds
- Assume further that H is modeled as a random oracle
- Then $(Gen, Sign, Verify)$ is EUF-CMA secure

Proof


Ch
$(N,e,d) \leftarrow RSAGen(1^\lambda)$
$Q = \emptyset$
If $H(m) = \perp$
$H(m) \leftarrow \mathbb{Z}_N^*$
$Q = Q \cup \{m_i\}$
$\sigma_i = H(m_i)^d$
Output 1 iff $(\sigma^*)^e = H(m^*)$
and $m^* \notin Q$
(N,e)
H
m
$H(m)$
Sign
m_i
σ_i
m^*, σ^*
$\mathcal{A}$

Proof

Reduction from RSA assumption:



q_h is an upper bound on hash queries

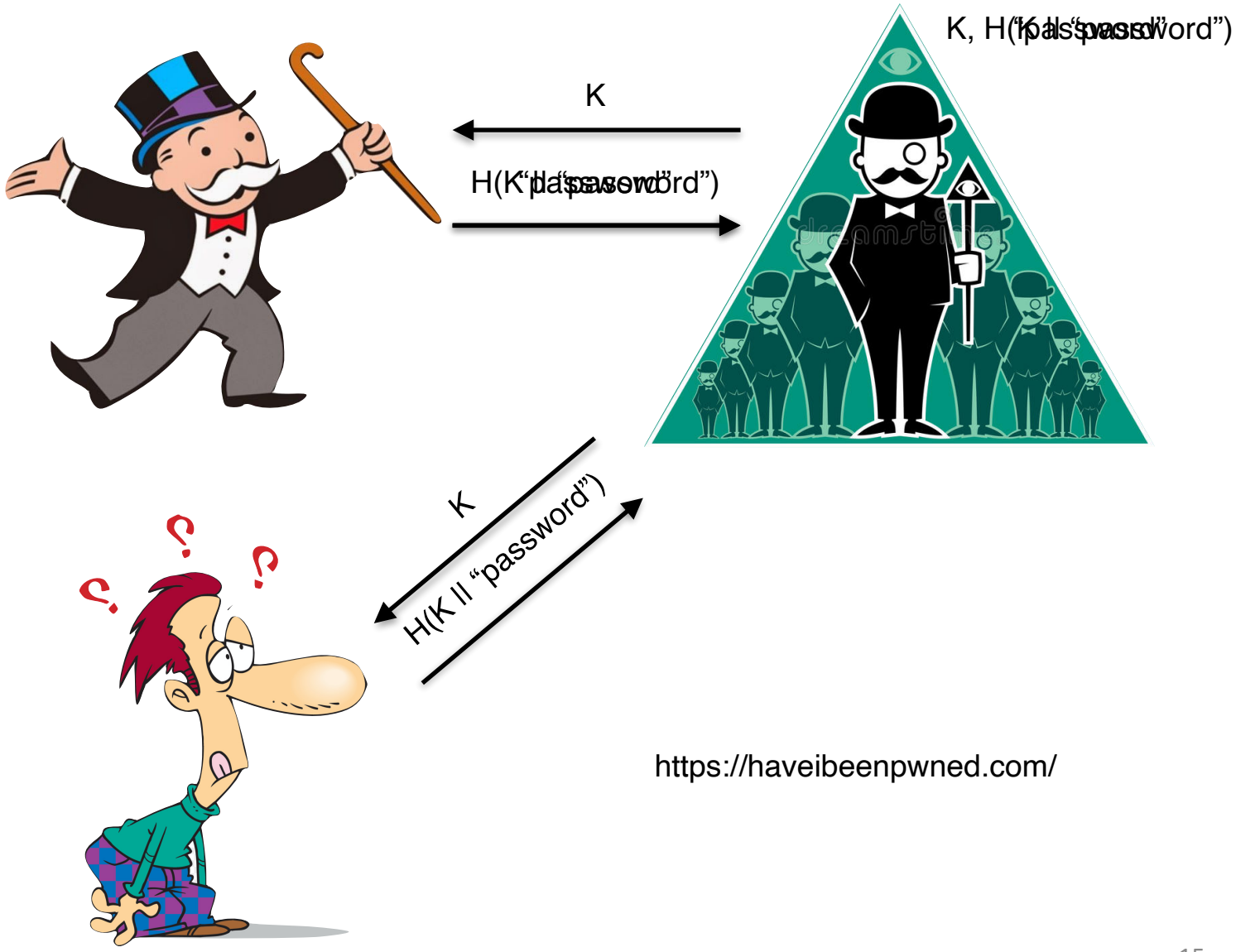
R succeeds with probability $\frac{1}{q_h}$ if $\mathcal{A}$ wins

Proof

Proof

How to prove yourself

- Basic Problem: Access Control
- How do you prove that you have the credentials to access?
- Passwords?
- Replay Attacks!



https://haveibeenpwned.com/

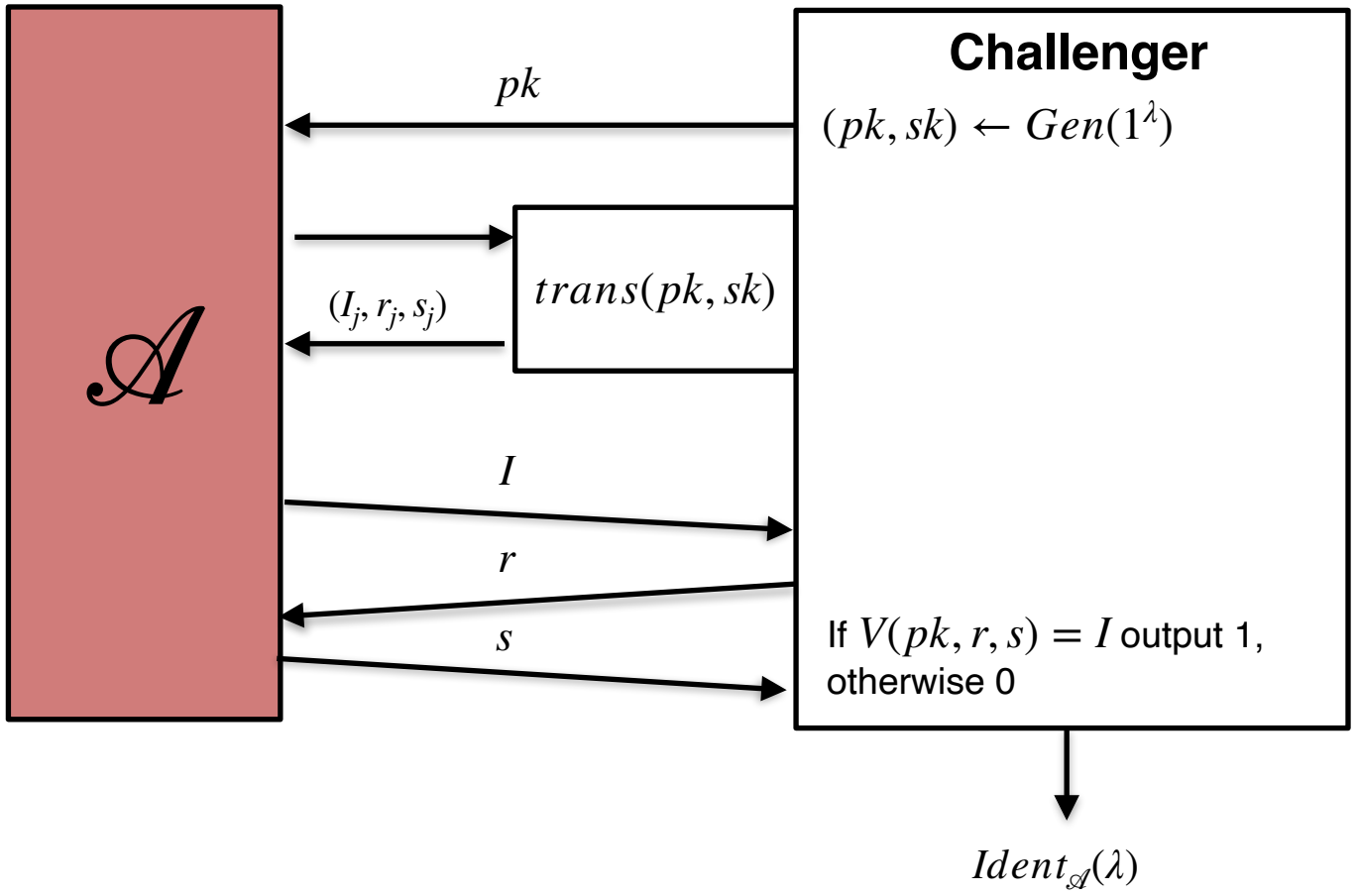
Identification Schemes

$$(pk, sk) \leftarrow Gen(1^\lambda)$$

Prover(sk)		Verifier(pk)
$(I, st) \leftarrow P_1(sk)$	$\xrightarrow{\quad I \quad}$	
		$r \leftarrow_\$ \Omega_{pk}$
	$\xleftarrow{\quad r \quad}$	
$s \leftarrow P_2(sk, st, r)$	$\xrightarrow{\quad s \quad}$	
		Accept if $V(pk, r, s) = I$

- Completeness: Verifier accepts with probability 1 for honest runs
- A public transcript consists of (I, r, s).
- Let $trans(pk, sk)$ be (randomized) algorithm which generates transcripts of protocol runs

$Ident_{\mathscr{A}}(\lambda)$ Experiment:



Definition

An encryption scheme (Gen, P_1, P_2, V) is **secure**, if it holds for **every PPT-adversary** $\mathscr{A}$ there exists a negligible function ν s.t. for all $\lambda \in \mathbb{N}$

$$\Pr[Ident_{\mathscr{A}}(\lambda) = 1] < \nu(\lambda)$$

Signature Schemes and Identification Schemes

- Signature Schemes immediately yield Identification Schemes

$$(vk, sk) \leftarrow Gen(1^\lambda)$$

Prover(sk) | Verifier(vk)

$$\xrightarrow{\quad 1 \quad}$$

$$r \leftarrow_\$ \{0,1\}^\lambda$$

$$\xleftarrow{\quad r \quad}$$

$$\sigma \leftarrow Sign(sk, r)$$

$$\xrightarrow{\quad \sigma \quad}$$

Accept if $Verify(vk, r, \sigma) = 1$

Signature Schemes and Identification Schemes

- Signature Schemes immediately yield Identification Schemes
- What about the converse?
- Idea: Let the prover choose the challenge r by himself to remove the second message m
- Obviously insecure if prover can choose r freely
- Idea of Fiat and Shamir: Make r a function of I …
- … and a message m we want to sign
- This function should be unpredictable for every new I and m

The Fiat Shamir Transform

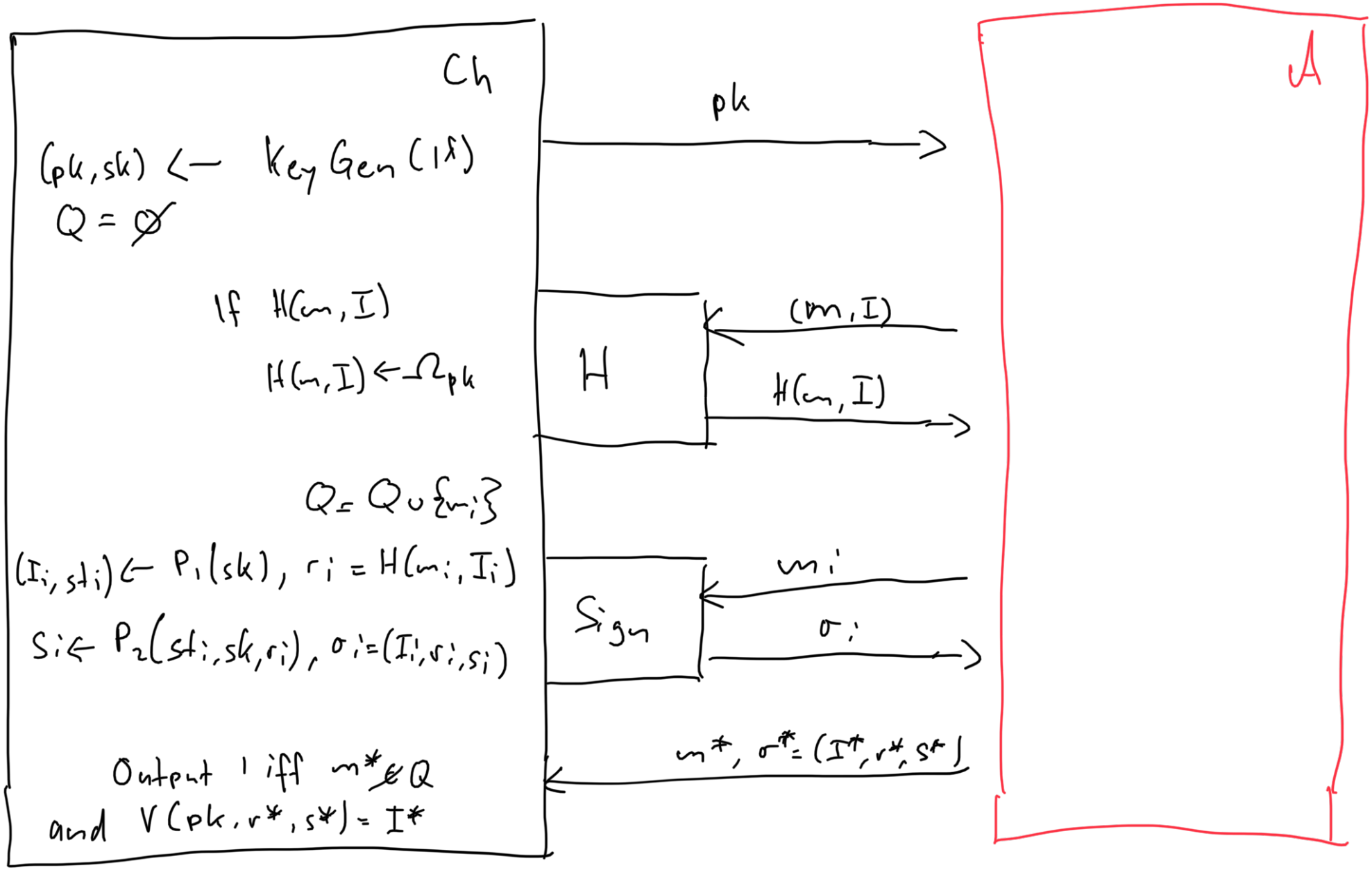
- Let (Gen, P_1, P_2, V) be an identification scheme
- Let $H : \{0,1\}^n \rightarrow \Omega_{pk}$ be a hash function
- The Fiat-Shamir transform $(Gen', Sign', Verify')$ of (Gen, P_1, P_2, V) is given as follows:
  - $Gen'(1^\lambda)$: Compute $(pk, sk) \leftarrow Gen(1^\lambda)$. Output $vk \leftarrow pk$ and sk
  - $Sign'(sk, m)$:
    - Compute $(I, st) \leftarrow P_1(sk)$
    - Compute $r \leftarrow H(I, m)$
    - Compute $s \leftarrow P_2(sk, st, r)$
    - Output $\sigma \leftarrow (I, r, s)$
  - $Verify'(vk = pk, m, \sigma = (I, r, s))$: If $V(pk, r, s) = I$ and $r = H(I, m)$ and output 1, otherwise 0

Security

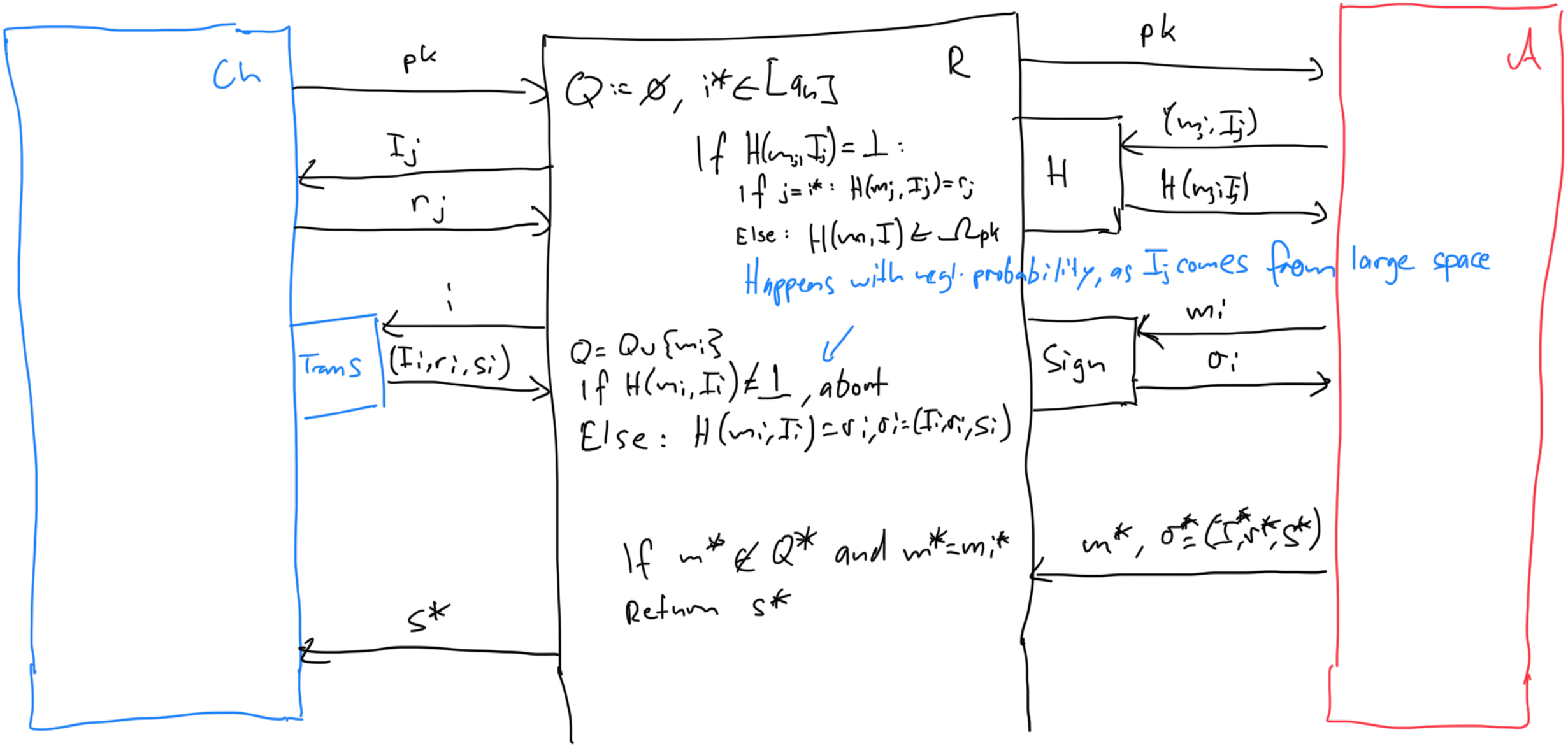
Theorem 9.2

- Assume that (Gen, P_1, P_2, V) is a secure identification scheme
- Assume that P_1 samples I uniformly from an exponentially large space (in λ)
- Assume further that H is modeled as a random oracle
- Then $(Gen', Sign', Verify')$ is an EUF-CMA secure signature scheme

Proof


Ch
(pk, sk) ← KeyGen(1^λ)
Q = ∅
If H(m, I)
H(m, I) ← Ω_pk
Q = Q ∪ {m_i}
(I_i, st_i) ← P_1(sk), r_i = H(m_i, I_i)
s_i ← P_2(st_i, sk, r_i), σ_i = (I_i, r_i, s_i)
Output 1 iff m* ∉ Q
and V(pk, r*, s*) = I*
pk
H
(m, I)
H(m, I)
Sign
m_i
σ_i
m*, σ* = (I*, r*, s*)
A

Proof Reduction to ID-Security:



Summary: Signature Basics

- Digital Signatures are the asymmetric version of message authentication codes
- Messages are signed using a secret signing key and can be verified using a public verification key
- Textbook RSA signatures have security issues
- Sensible security notion for signatures is EUF-CMA security, as for MACs
- RSA Hash-and-Sign is EUF-CMA secure in the random oracle model

Summary: Signatures and ID schemes

- Naive attempts for access control are often susceptible to replay attacks
- Identification schemes provide security against replay attacks
- Signature schemes immediately imply identification schemes
- Conversely, every 3-round identification scheme can be transformed into a signature scheme via the Fiat Shamir transform
- The security proof is in the random oracle model